

蓝牙低功耗安全-BLE Secure Connections 协议

刘焱¹

(南京邮电大学 南京市 210023)¹

摘 要: 蓝牙低功耗 (Bluetooth Low Energy, BLE) 已经广泛应用于可穿戴设备、智能家居、医疗传感、工业物联网和移动支付外设等近距离无线通信场景。BLE Secure Connections 是 BLE 安全体系中最重要安全配对机制之一, 它以椭圆曲线 Diffie-Hellman 密钥协商为基础, 结合 AES-CCM 链路加密、身份解析密钥、签名密钥和多种关联模型, 实现设备间的认证、加密、绑定和隐私保护。围绕 BLE Secure Connections 协议展开单一对象分析, 首先说明中心设备、外围设备、GAP、GATT、ATT、SMP、控制器和主机在 BLE 安全部署中的系统位置; 随后从设备身份域、配对认证域、链路加密域、隐私保护域和密钥生命周期域梳理其安全边界; 进一步分析 ECDH P-256 密钥协商、确认值计算、短期密钥与长期密钥派生、Numeric Comparison、Passkey Entry、Out-of-Band 以及可解析私有地址等关键技术; 最后结合 BLE 降级攻击、Just Works 中间人风险、重复配对、弱随机数、隐私跟踪和实现差异等问题, 提出强制安全连接、保护能力协商、优化密钥生命周期、增强隐私地址轮换和建立日志审计机制等改进方案。

关键词: 蓝牙低功耗, BLE Secure Connections, 安全配对, ECDH, AES-CCM, 隐私保护

中图分类号 TP393.08 文献标识码 A DOI (投稿时不提供 DOI 号)

Bluetooth Low Energy Security-BLE Secure Connections Protocol: Security Architecture, Key Technologies and Improvement Analysis

Liu Yan¹

(Nanjing University of Posts and Telecommunications, Nanjing 210023, China)¹

Abstract Bluetooth Low Energy (BLE) is widely used in wearable devices, smart homes, medical sensors, industrial IoT and mobile peripherals. BLE Secure Connections is one of the most important pairing mechanisms in the BLE security architecture. Based on elliptic-curve Diffie-Hellman key agreement and combined with AES-CCM link encryption, identity resolving keys, signing keys and several association models, it supports authentication, encryption, bonding and privacy protection between devices. This paper focuses on BLE Secure Connections as a single protocol object. It first explains the positions of the central device, peripheral device, GAP, GATT, ATT, SMP, host and controller in BLE security deployment. It then analyzes the security domains, attack surfaces and protection mechanisms of the protocol, followed by a detailed discussion of ECDH P-256, confirmation value calculation, key derivation, Numeric Comparison, Passkey Entry, Out-of-Band pairing and resolvable private addresses. Finally, considering downgrade attacks, man-in-the-middle risks in Just Works, repeated pairing, weak randomness, privacy tracking and implementation differences, several improvements are proposed, including mandatory Secure Connections, protected capability negotiation, key lifecycle management, enhanced private address rotation and security auditing.

Keywords Bluetooth Low Energy, BLE Secure Connections, Secure pairing, ECDH, AES-CCM, Privacy protection

1 引言

1.1 研究背景与动机

在无线网络课程的研究对象中, 蓝牙低功耗是一类与无线局域网同样重要、但应用场景明显不同的近距离无线通信技术。无线局域网通常承担较高吞吐量的局域接入任务, 而 BLE 更强调低功耗、低成本、短报文和长期在线能力, 因此被大量嵌入手环、耳机、门锁、血糖仪、温湿度传感器、工业标签、资产定位器和智能家居中。BLE 设备往往体积小、算力弱、交互界面有限, 却又直接接触用户身份、位置、健康数据和家庭控制指令。一旦安全配对或链路加密出现缺陷, 攻击者不一定需要突破互联网边界, 只要靠近无线覆盖范围, 就可能监听、伪造或劫持设备通信。

BLE 的安全问题并不只是“是否加密”的问题。许多设备虽然开启了链路层加密, 但配对时使用 Just Works 模式, 缺少对中间人的抵抗能力; 有些设备虽然支持 LE Secure Connections, 却在兼容旧手机或旧固件时允许回退到 Legacy Pairing; 还有一些设备在绑定后长期复用密钥, 私有地址轮换不充分, 导致用户在商场、医院或办公楼中被持续跟踪。随着可穿戴设备和物联网终端数量快速增长, BLE Secure Connections 的系统组成、安全域、攻击方式和关键算法值得进行单独、深入的分析。

本文选择 BLE Secure Connections 作为唯一研究对象, 而不再泛泛罗列 Wi-Fi、ZigBee、蜂窝网等多种无线协议。这样做的原因在于, BLE Secure Connections 兼具密码协议、低功耗系统和人机交互三种属性: 从密码学角度看, 它使用

ECDH P-256 生成共享秘密, 并以 AES-CMAC、AES-CCM 等算法完成确认和加密; 从系统角度看, 它连接 GAP 发现、SMP 配对、GATT 数据服务和控制器链路层; 从用户角度看, 它的安全等级又受显示屏、键盘、二维码、NFC 和确认按钮等输入输出能力影响。只有围绕一个协议展开, 才能把其安全边界和改进方向讲清楚。

1.2 BLE Secure Connections 的基本定位

BLE Secure Connections 是 Bluetooth Core Specification 中面向低功耗蓝牙的安全配对机制。它相对于早期 Legacy Pairing 的核心变化, 是使用椭圆曲线 Diffie-Hellman 建立共享密钥, 而不是让监听者能够从配对交互中推导短期密钥。标准中 Security Manager Protocol (SMP) 负责配对、绑定、密钥分发和安全请求等流程, 链路层随后使用分发得到的长期密钥对连接进行加密[1-2]。因此, BLE Secure Connections 并不直接承载应用数据, 而是为后续 ATT/GATT 数据访问提供认证、加密和密钥材料。

BLE Secure Connections 的安全目标可以概括为四点。第一, 机密性: 攻击者即使监听空中报文, 也不能恢复应用数据。第二, 完整性: 攻击者不能随意篡改加密连接中的数据包而不被发现。第三, 认证性: 在合适的关联模型下, 设备能够确认对方不是中间人伪造的设备。第四, 隐私性: 设备可以通过可解析私有地址隐藏固定蓝牙地址, 减少被长期跟踪的风险。需要注意的是, 这些目标并非在所有配对方式下都自动成立。例如 Just Works 虽然使用 Secure Connections 的 ECDH, 但由于缺少用户确认或外部信道, 仍无法有效抵抗主动中间人攻击。

到稿日期: 返修日期:

本文受 xx 基金资助。

作者名 (出生年-), 性别, 学历, 职称, 主要研究方向为 xx, E-mail: xx(通信作者)。若是 CCF 会员, 请注明。

2 BLE Secure Connections 协议的系统组成

2.1 BLE 通信实体与协议栈位置

从系统组成看, BLE Secure Connections 涉及中心设备、外围设备、主机、控制器、应用服务和安全管理器等多个实体。外围设备通常通过 Advertising 信道周期性广播自身存在, 例如智能手环、蓝牙温度计或门锁; 中心设备负责扫描、发起连接和访问服务, 例如手机、平板或网关。二者建立连接后, 控制器负责跳频、连接事件、链路层确认和加密包处理, 主机则负责 GAP、GATT、ATT、L2CAP 和 SMP 等协议逻辑。应用层通过 GATT 特征值读写或通知机制交换数据, 而是否允许访问某些特征, 通常取决于当前连接是否已经完成配对、绑定和加密。

在 BLE 协议栈中, SMP 位于主机层, 通过固定的 L2CAP 信道传输配对请求、配对响应、公钥、确认值、随机数、DHKey Check、密钥分发等消息。SMP 的输出包括 LTK、IRK、CSRK 等密钥材料。LTK 用于后续连接中的链路加密, IRK 用于解析可解析私有地址, CSRK 用于无连接场景中的数据签名。控制器并不理解全部配对语义, 但会根据主机下发的密钥执行链路层加密和包完整性保护。由此可见, BLE Secure Connections 是连接应用访问控制、主机安全策略和控制器加密能力的核心协议。

2.2 配对、绑定与密钥层次

BLE 安全流程需要区分配对和绑定。配对是两个设备在当前连接中建立加密关系的过程, 绑定则是在配对成功后保存密钥, 使未来重新连接时不必再次完整配对。对于只需要一次性数据交换的设备, 可以只配对不绑定; 对于手环、耳机、门锁等长期使用设备, 绑定能够减少用户操作并提升连接效率。但绑定也引入密钥生命周期风险: 如果设备丢失、转让或恢复出厂设置不彻底, 旧密钥可能继续有效; 如果应用没有提供删除绑定关系的界面, 用户难以及时撤销信任。

BLE Secure Connections 的密钥层次比表面看到的“蓝牙配对码”复杂得多。ECDH 过程生成共享秘密 DHKey, 随后通过确认和派生过程生成连接所需密钥。LTK 是长期加密密钥, EDIV 和 Rand 等传统字段在 Secure Connections 中的作用与 Legacy Pairing 不完全相同; IRK 用于根据随机地址恢复真实身份; CSRK 用于在特定场景下对数据进行签名。把这些密钥区分开来, 有助于理解 BLE 的安全边界: 加密保护的是当前连接数据, 身份解析保护的是地址隐私, 签名保护的是无连接数据来源, 而绑定数据库保护的是未来重连信任关系。

2.3 表格化系统分析

表 1 BLE Secure Connections 阶段、关键材料与安全关注点

阶段	主要参与方	关键材料	安全目标	主要风险
设备发现	中心、外围	地址、广播数据、能力	发现目标设备	伪装设备、隐私跟踪
配对协商	主机 SMP	IO 能力、认证需求	选择关联模型	能力降级、中间人
公钥交换	双方主机	P-256 公钥、随机数	生成共享秘密	弱随机数、非法点
确认检查	双方主机	确认值、DHKey Check	验证配对上下文	确认绕过、状态机错误
密钥分发	双方主机/控制器	LTK、IRK、CSRK	加密与绑定	密钥泄露、长期复用

如表 1 所示, BLE Secure Connections 的安全并不是单一算法能够决定的。设备发现阶段会暴露广播地址和服务信息, 配对协商阶段决定是否具备中间人保护, 公钥交换阶段决定共享秘密强度, 确认检查阶段绑定双方上下文, 密钥分发阶段则影响后续重连和隐私保护。任何一个阶段处理不当, 都可能使最终的加密连接失去预期安全性。

3 BLE Secure Connections 安全体系

3.1 安全域划分

BLE Secure Connections 的安全体系可以划分为设备身份域、配对认证域、链路加密域、应用授权域、隐私保护域和密钥生命周期域。设备身份域关注设备地址、设备名称、广播内容和身份解析密钥, 决定“我正在连接谁”。配对认证域关注关联模型、用户确认、公钥交换和确认值, 决定“对方是否参与了同一安全配对过程”。链路加密域关注控制器是否启用加密、加密密钥长度是否足够、数据包完整性是否得到保护。应用授权域关注 GATT 服务和特征值是否要求认证读取、加密写入或授权访问。隐私保护域关注私有地址轮换、广播数据最小化和可解析地址解析。密钥生命周期域关注绑定数据库、密钥撤销、设备丢失和恢复出厂设置。

这些安全域相互影响。例如, 设备身份域如果只依赖可伪造的设备名称, 攻击者就可以搭建同名设备诱导用户配对; 配对认证域如果使用 Just Works, 链路层加密仍然可能建立在中间人转发的基础上; 应用授权域如果允许未加密读取敏感特征值, 即使配对协议本身正确, 也无法保护数据; 隐私保护域如果长期使用固定随机地址, 攻击者可以通过被动扫描建立用户移动轨迹。因此, BLE 安全分析必须从 Secure Connections 协议出发, 同时延伸到应用权限和设备管理策略。

3.2 威胁模型与攻击方式

BLE 面对的攻击者可以分为被动监听者、主动中间人、伪装设备、降级攻击者、隐私跟踪者、重复配对攻击者和实现侧信道攻击者。被动监听者只记录空中报文, 希望从配对或加密连接中恢复明文。Secure Connections 通过 ECDH 降低了被动恢复密钥的可能性。主动中间人能够同时与中心设备和外围设备通信, 修改配对请求中的 IO 能力或认证需求, 诱导双方选择较弱关联模型。伪装设备通过复制名称、服务 UUID 和外观信息欺骗用户连接。隐私跟踪者长期扫描固定地址或广播特征, 推断用户位置和行为。重复配对攻击者诱导设备删除旧绑定或建立新绑定, 从而控制后续连接关系。实现侧信道攻击者则利用随机数质量、错误码差异、配对状态管理和绑定数据库缺陷获取额外优势。

早期研究表明, BLE Legacy Pairing 在某些模式下容易受到被动嗅探和密钥恢复影响[5]。Secure Connections 改进了这一点, 但并没有消除所有攻击面。USENIX Security 2020 的研究展示了 BLE 安全配对中的降级问题: 如果设备或移动端框架没有正确处理 Secure Connections Only、状态管理和错误恢复, 攻击者可以迫使配对运行在更弱模式下, 而用户未必能够察觉[6]。这说明 BLE 安全不仅取决于标准本身, 还取决于操作系统、SDK、芯片固件和应用逻辑是否正确实现标准要求。

3.3 安全技术方案总体结构

BLE Secure Connections 的安全技术方案可以概括为“能力协商+ECDH 密钥协商+确认值验证+链路加密+密钥分发与绑定”。能力协商阶段交换 IO 能力、OOB 数据可用性、认证需求和密钥大小, 决定使用 Numeric Comparison、Passkey Entry、Out-of-Band 或 Just Works。ECDH 阶段交换 P-256 公钥并计算 DHKey。确认阶段通过随机数、地址、IO 能力和公钥等上下文计算确认值和 DHKey Check, 防止攻击者在不知道共享秘密的情况下完成配对。链路加密阶段使用 LTK 启用控制器加密。密钥分发阶段保存 IRK、CSRK 等材料, 用于未来身份解析、数据签名和快速重连。

这一结构的核心思想是: 人类可操作的确认动作不直接变成密钥, 密钥由椭圆曲线协商产生; 用户确认、Passkey

到稿日期: 返修日期:
本文受 xx 基金资助。

作者名(出生年-), 性别, 学历, 职称, 主要研究方向为 xx, E-mail: xx(通信作者)。若是 CCF 会员, 请注明。

或 OOB 信道用于抵抗中间人；控制器层加密用于保护后续数据；绑定数据库用于延续信任关系。这样既适应了 BLE 设备低功耗和弱交互的现实，又为较高安全等级设备提供了选择更强关联模型的空间。

4 BLE Secure Connections 关键技术分析

4.1 ECDH P-256 密钥协商

BLE Secure Connections 的核心密码技术是基于 P-256 椭圆曲线的 ECDH 密钥协商。双方分别生成私钥和公钥，交换公钥后计算相同的 DHKey。攻击者即使监听到两个公钥，也难以在不知道任一私钥的情况下求得共享秘密。与 Legacy Pairing 中基于 TK 的短期密钥生成方式相比，ECDH 的引入显著提高了对被动监听的抵抗能力。NIST 对密钥管理和安全强度的建议强调，应根据算法安全强度、密钥长度和生命周期综合评估密钥使用方式[9]；在 BLE 中，P-256 的安全性足以覆盖多数消费级和工业物联网场景。

工程实现中，ECDH 的安全依赖随机数质量和公钥验证。私钥必须由可靠随机数生成器产生，不能使用可预测种子；收到对方公钥后，应检查其是否属于正确曲线、是否为无效点或小阶点。虽然标准定义了协议行为，但许多低成本芯片和 SDK 对错误处理、边界检查和调试日志的处理差异较大。若实现为了节省时间跳过验证，攻击者可能利用非法点或状态机异常影响配对结果。因此，ECDH 不只是数学公式，还需要与安全随机数、输入验证和常数时间运算结合。

4.2 AES-CCM 链路加密与密钥派生

BLE 加密连接使用 AES-CCM 提供机密性和完整性。AES 是对称分组密码标准[3]，CCM 模式结合计数器加密和 CBC-MAC 认证，适合短报文、低功耗和硬件加速场景[4]。BLE 控制器在链路层对数据包进行加密和认证，应用层通常不直接处理 AES-CCM 细节。这样做的优点是减轻应用开发者负担，使加密成为连接属性；缺点是如果应用错误地允许敏感特征在未加密状态下访问，链路层能力并不会自动弥补访问控制缺陷。

密钥派生方面，Secure Connections 使用 DHKey、随机数、地址、配对方法和确认上下文生成后续密钥材料。派生过程必须确保不同用途密钥相互隔离，例如加密密钥不能直接复用为身份解析密钥，签名密钥也不应与链路加密密钥混同。密钥大小协商同样重要，设备不应为了兼容旧实现而接受过短加密密钥。对于医疗、门锁和支付相关外设，应配置为要求认证配对和足够密钥长度，并在应用层再次检查当前连接安全级别。

4.3 关联模型：Just Works、Numeric Comparison、Passkey Entry 与 OOB

BLE Secure Connections 的安全等级很大程度取决于关联模型。Just Works 不需要用户输入或确认，适用于无屏幕、无键盘的小型设备，但不能抵抗主动中间人。Numeric Comparison 要求双方显示同一数字，用户确认两端数字一致，适合手机、电脑、智能电视等具有显示和确认能力的设备。Passkey Entry 要求一方显示或生成六位数字，另一方输入，用于具备键盘或按钮输入的设备。Out-of-Band 使用 NFC、二维码或有线接口等外部信道传递认证数据，适合对安全要求较高但 BLE 交互能力有限的设备。

这些关联模型体现了 BLE 安全的现实妥协。许多物联网设备没有屏幕和键盘，只能使用 Just Works；但对于门锁、医疗传感器、车载钥匙和支付外设，单纯依赖 Just Works 风险过高。设备厂商应在设计阶段为高价值操作提供更强的用户确认方式，例如在门锁上设置物理按键确认，在包装盒或

设备标签上提供一次性二维码，在手机应用中显示安全等级并阻止静默降级。

4.4 身份隐私与可解析私有地址

BLE 设备如果长期使用固定公共地址，攻击者可以通过被动扫描追踪设备和用户。为降低这一风险，BLE 引入私有地址机制，其中可解析私有地址可以由拥有 IRK 的可信设备解析，而普通监听者只能看到不断变化的随机地址。这样，已绑定的手机可以识别手环或耳机，陌生扫描者则难以稳定关联同一设备。隐私地址机制对可穿戴设备尤其重要，因为这些设备通常随人移动，暴露的地址可能反映用户生活规律。

隐私保护不能只依赖地址随机化。广播数据中的设备名称、服务 UUID、厂商数据、发射功率和出现时间也可能形成指纹。如果设备虽然轮换地址，却在广播中长期携带唯一序列号或固定厂商字段，攻击者仍可追踪。因此，改进 BLE 隐私需要同时处理地址轮换周期、广播内容最小化、连接后再暴露敏感服务、以及绑定设备的身份解析策略。

4.5 协议流程图

图 1 给出了 BLE Secure Connections 从设备发现到绑定密钥保存的主要逻辑链路。该图采用黑白灰方式表示协议阶段，强调配对能力协商、ECDH 公钥交换、DHKey Check 和密钥分发之间的顺序关系。

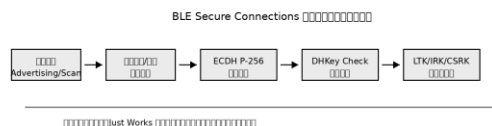


图 1 BLE Secure Connections 安全配对与密钥生成流程

5 BLE Secure Connections 安全缺陷与改进方案

5.1 已知缺陷：中间人、降级、重复配对与隐私泄露

BLE Secure Connections 的理论安全目标较强，但实际部署中仍存在若干典型缺陷。第一，Just Works 缺少中间人保护。攻击者可以在用户未察觉时同时与两端建立连接，并分别完成配对，使两端都以为自己连接了真实设备。第二，降级攻击风险突出。若设备同时支持 Legacy Pairing 和 Secure Connections，或手机系统在错误恢复时自动回退，攻击者可能通过干扰、篡改能力字段或制造失败诱导弱模式。第三，重复配对和绑定管理容易被忽视。攻击者可以诱导用户删除旧绑定、重新配对假设备，或利用设备恢复出厂设置不彻底的问题继续使用旧密钥。

第四，隐私泄露问题具有长期性。许多 BLE 设备即使使用私有地址，也会在广播包中包含可识别服务、厂商数据或固定名称，导致地址随机化效果降低。第五，低成本设备的随机数、密钥存储和调试接口可能不安全。若随机数可预测，ECDH 私钥质量下降；若密钥明文存储在闪存或调试口未关闭，攻击者可以通过物理接触提取绑定信息。第六，应用层权限配置错误也很常见，例如敏感 GATT 特征允许未认证读取，或者固件升级特征只要求普通加密而不要求授权。

5.2 改进一：强制 Secure Connections Only 与高安全关联模型

第一项改进是对关键设备强制 Secure Connections Only。对于门锁、医疗设备、资产跟踪网关和支付外设，应禁止 Legacy Pairing，并拒绝密钥长度不足或缺少认证的连接。设备在配对请求和响应中声明较高认证需求后，应用层还应在访问敏感特征前检查连接是否达到期望安全级别，避免“链路已加密但未认证”的误用。对用户可感知设备，应优先使

到稿日期： 返修日期：

本文受 xx 基金资助。

作者名（出生年-），性别，学历，职称，主要研究方向为 xx，E-mail: xx(通信作者)。若是 CCF 会员，请注明。

用 Numeric Comparison 或 Passkey Entry; 对无屏幕设备, 应结合二维码、NFC 或物理按钮实现 OOB 或本地确认。

这种改进的核心不是盲目追求复杂, 而是根据风险选择适当交互。廉价温度计可以接受较低安全等级, 但门锁不能因为没有屏幕就默认 Just Works。厂商应在产品设计阶段为高风险操作预留最小确认能力, 例如长按按钮进入配对、短时间窗口允许新绑定、手机端显示设备指纹或二维码校验结果。这样可以在不显著增加功耗的情况下提高中间人攻击成本。

5.3 改进二: 保护能力协商并检测降级

第二项改进是保护配对能力协商和降级检测。BLE 配对请求中的 IO 能力、OOB 标志和认证需求会影响最终关联模型, 如果这些字段被攻击者篡改, 就可能从 Numeric Comparison 降级为 Just Works, 或从 Secure Connections 降级为 Legacy Pairing。因此, 设备应把最终协商出的配对方法、安全级别、密钥长度和是否使用 Secure Connections 记录到绑定数据库中。后续连接若发现同一设备突然要求更低安全等级, 应提示用户或拒绝连接, 而不是静默接受。

移动应用也应承担降级检测责任。许多 BLE 设备依赖手机 App 完成配置, 如果 App 只调用系统配对接口而不检查安全结果, 用户很难知道当前连接是否具备中间人保护。建议 App 在首次绑定后保存预期安全等级, 并在每次连接时读取系统暴露的加密和认证状态。若安全等级低于历史记录, 应阻止敏感操作并提示重新配对。

5.4 改进三: 密钥生命周期、绑定撤销与隐私地址策略

第三项改进是完善密钥生命周期管理。设备应为绑定数据库提供明确的删除、重置和更新机制。用户更换手机、出售设备或设备丢失时, 应能够撤销旧 IRK、LTK 和 CSRK。对于长期在线设备, 可以设置密钥更新策略, 在固件升级、重大配置变更或检测到异常配对后重新建立绑定。密钥应存储在安全区域或受访问控制的非易失存储中, 生产调试接口应在出厂前关闭, 防止通过 UART、SWD 或未授权调试提取密钥。

隐私地址策略也需要细化。设备应启用可解析私有地址, 并根据使用场景选择合理轮换周期。广播数据应避免携带唯一序列号、用户姓名或可直接识别设备的字段; 敏感服务可以在连接加密后再暴露完整特征; 网关和手机端应妥善保护 IRK, 避免将身份解析能力泄露给无关应用。对于医院、校园和商场等高密度环境, 隐私地址和广播最小化可以显著降低被动跟踪风险。

5.5 改进四: 实现安全、日志审计与后量子过渡

第四项改进面向工程实现和未来演进。BLE 芯片和 SDK 应提供经过验证的 ECDH、公钥验证、AES-CCM 和随机数接口, 应用开发者不应自行拼接底层密码算法。固件应统一错误返回, 避免通过错误码区分“确认失败”“密钥错误”“能力不匹配”等细节。日志审计应记录配对时间、配对方式、是否 Secure Connections、密钥长度、失败次数、绑定变更和异常降级事件。对于网关类设备, 可以将这些日志上报到管理平台, 以便发现批量攻击或异常配对。

从长期看, BLE 还需要关注后量子密码对 ECDH 的影响。当前 BLE Secure Connections 依赖椭圆曲线离散对数问题, 短期内仍适合低功耗设备; 但对于生命周期很长的工业传感器、医疗植入设备和车联网外设, 未来可能需要研究轻量级后量子密钥协商或混合密钥建立方案。考虑到 BLE 报文长度、功耗和连接时延限制, 后量子过渡不能简单照搬互

联网 TLS 方案, 而应结合广播、连接事件和芯片硬件加速重新设计。

6 总结与展望

围绕“蓝牙低功耗安全-BLE Secure Connections 协议”这一单一对象可以看到, BLE 安全并不是一个单纯的加密开关, 而是由设备发现、配对协商、ECDH 公钥交换、确认值验证、链路层 AES-CCM 加密、密钥分发、绑定数据库和隐私地址共同组成的系统工程。Secure Connections 相比 Legacy Pairing 的关键进步在于引入 ECDH, 使被动监听者难以从配对报文中恢复会话密钥; 同时通过 Numeric Comparison、Passkey Entry 和 OOB 等关联模型, 为抵抗中间人提供了可选手段。

但是, BLE Secure Connections 的安全性并非绝对。Just Works 仍缺少中间人保护, 能力协商和错误恢复可能导致降级, 绑定数据库和密钥撤销常被忽略, 广播数据和固定特征可能破坏隐私, 低成本设备的随机数和调试接口也可能带来实现风险。因此, 改进方向应集中在强制 Secure Connections Only、优先采用认证关联模型、保护能力协商、检测安全等级下降、完善密钥生命周期、启用可解析私有地址、减少广播指纹、加强日志审计和规范 SDK 安全接口等方面。

对于家庭和个人设备, 最直接的建议是及时更新固件、删除不再使用的绑定、避免在公共场所随意配对未知设备。对于医疗、门锁和工业物联网设备, 应将 BLE 安全能力纳入产品验收标准, 明确要求安全配对、足够密钥长度、隐私地址和安全重置流程。对于标准制定者和芯片厂商, 应继续推动配对状态机测试、降级攻击检测、隐私保护默认开启和后量子轻量化方案研究。只有把协议设计、实现规范、用户交互和运维管理结合起来, BLE Secure Connections 才能真正支撑可穿戴设备和物联网场景中的无线网络安全。

参考文献

- [1] Bluetooth SIG. Bluetooth Core Specification Version 5.4[S]. Kirkland: Bluetooth SIG, 2023.
- [2] Bluetooth SIG. Part H: Security Manager Specification, Bluetooth Core Specification Version 5.4[S/OL]. Kirkland: Bluetooth SIG, 2023.
- [3] National Institute of Standards and Technology. Advanced Encryption Standard (AES): FIPS 197[S]. Gaithersburg: NIST, 2001.
- [4] DWORKIN M. Recommendation for Block Cipher Modes of Operation: The CCM Mode for Authentication and Confidentiality: NIST Special Publication 800-38C[S]. Gaithersburg: NIST, 2004.
- [5] RYAN M. Bluetooth: With Low Energy Comes Low Security[C]//Proceedings of the 7th USENIX Workshop on Offensive Technologies. Berkeley: USENIX Association, 2013.
- [6] ZHANG Y, WENG J, DROZDOWSKI P, et al. Breaking Secure Pairing of Bluetooth Low Energy Using Downgrade Attacks[C]//Proceedings of the 29th USENIX Security Symposium. Berkeley: USENIX Association, 2020: 37-54.
- [7] CÄSAR M, PAWELSKI T, STEFFEN S, et al. A survey on Bluetooth Low Energy security and privacy[J]. Computer Networks, 2022, 205: 108712.
- [8] PEKER Y K, ACARMAN T, YILDIRIM M, et al. On the Security of Bluetooth Low Energy in Two Consumer Wearable Devices[J]. Sensors, 2022, 22(3): 1037.
- [9] BARKER E. Recommendation for Key Management: Part 1-General: NIST Special Publication 800-57 Part 1 Revision 5[S]. Gaithersburg: NIST, 2020.
- [10] CAO Y, YANG Z, XU W, et al. BLE-GUARD: A Practical Approach to Protecting BLE Devices against Man-in-the-Middle Attacks[C]//IEEE Conference on Communications and Network Security. New York: IEEE, 2019: 1-9.